

OpenCode SECURITY.md 文档解读

这份安全说明文档明确了 **OpenCode（本地运行的 AI 编码助手）** 的安全边界、权限机制、威胁模型、上报规则，重点是：**它的权限弹窗只是用户交互提醒，不是安全沙箱隔离。**

一、项目基础定位

OpenCode 是运行在用户本机的 AI 编码助手，内置 Agent 智能代理，具备三类高危能力：

- 1. Shell 命令执行
- 2. 文件读写操作
- 3. 网络网页访问

⚠️ 核心关键点：**Agent 没有沙箱隔离。**

二、权限机制工作原理

1. 权限系统本质：仅 UX 交互提示，不是安全防护

文档原文：权限系统是 **UX feature（用户体验功能）**，不是安全隔离。

- 行为：Agent 要执行 shell 命令、写入文件等高风险动作时，**会弹窗请求用户确认。**
- 作用：提醒用户当前 AI 将要做什么操作，让用户人工选择允许 / 拒绝。
- **！** 不具备的能力：**不能阻止绕过、不能做进程隔离、不能防御恶意逻辑。**
- 如果想要真正安全隔离：必须自己把 OpenCode 部署在 Docker 容器 或者虚拟机内部运行，靠容器 / 虚拟机做隔离，而不是依靠项目自带权限提示。

2. Server Mode（服务器模式）安全规则

服务器模式属于**用户手动开启的可选功能，默认不开启：**

- 1. 开启之后，需要配置环境变量 `OPENCODE_SERVER_PASSWORD`，启用 HTTP 基础身份认证。
- 2. 如果不设置密码，服务会无认证直接运行，程序会给出警告。
- 3. **安全责任归终端用户：**开启服务之后产生的所有访问、风险，不属于项目的安全漏洞，需要用户自己做好防护。

三、不在漏洞报告范围内（Out of Scope）

下面这些场景，项目团队不视作本项目漏洞，收到这类报告不会处理：

--	--

类别	说明
开启 Server 模式后的服务器访问	用户主动开启服务，API 被访问属于预期行为
“突破权限系统逃逸”	本来就不是沙箱，不存在逃逸漏洞
LLM 大模型服务商的数据处理	发给大模型服务商的数据，遵守服务商自身隐私策略，不属于 OpenCode 问题
外部 MCP 服务器行为	用户自行配置的第三方 MCP 服务，不在项目信任边界内
恶意配置文件	配置文件由用户全权掌控，篡改配置不算攻击面

四、安全报告提交特殊规则

- 1. **✗不接受 AI 生成的安全报告**：提交 AI 自动产出的漏洞报告会直接被项目封禁。团队收到大量 AI 报告，没有资源审核。
- 2. 正常漏洞上报渠道：GitHub 项目的 Security Advisory 页面「Report a Vulnerability」提交漏洞。
- 3. 超时升级：提交报告后**6 个工作日没有收到回复**，可以发邮件 security@anoma.ly 进行升级催促。
- 4. 流程：提交后团队会回复跟进，过程中同步修复进度，可能会向上报人索要更多复现信息。

五、总结

- 1. OpenCode 的权限确认弹窗**仅做人工提醒，没有安全隔离能力**，AI 代理拥有本机的真实操作能力；
- 2. 需要强隔离必须依赖 Docker/VM，不要信任内置权限机制作为安全防线；
- 3. 服务模式需要用户手动开启，认证、防护责任完全交给用户；
- 4. 很多“看起来高危”的场景被划定在漏洞范围之外；同时拒绝 AI 批量生成的安全报告。

如果你需要，我可以帮你整理一份该项目的安全风险清单（运维使用注意点）。

（注：部分内容可能由 AI 生成）